



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-28318 SolarWinds Serv-U Uncontrolled Resource Consumption Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-05
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-28318 SolarWinds Serv-U Uncontrolled Resource Consumption Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-05 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-28318 SolarWinds Serv-U Uncontrolled Resource Consumption Vulnerability

1. Executive Summary

CVE-2026-28318 is a high-severity unauthenticated denial-of-service vulnerability affecting SolarWinds Serv-U. According to the SolarWinds CNA record and NVD, specially crafted POST requests using the `Content-Encoding: deflate` header can crash the Serv-U service without prior authentication. CISA added the issue to the Known Exploited Vulnerabilities (KEV) catalog on 2026-06-05, which materially raises operational risk for exposed internet-facing Serv-U deployments.

For defenders, the immediate concern is service disruption against externally reachable managed file transfer infrastructure. Organizations running vulnerable Serv-U instances should prioritize emergency patching to Serv-U 15.5.4 Hotfix 1, enforce temporary mitigation by blocking POST requests containing `Content-Encoding: deflate` if patching cannot be completed immediately, and validate that internet-facing transfer services are behind appropriate reverse-proxy, WAF, and rate-limiting controls.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-28318
Vendor	SolarWinds
Product	Serv-U
Weakness	CWE-400 Uncontrolled Resource Consumption
CVSS v3.1	7.5 High
Attack Vector	Network
Privileges Required	None
User Interaction	None
Impact	Availability only; service crash / denial of service
Known Exploitation	Yes - listed in CISA KEV
Fixed Version	Serv-U 15.5.4 Hotfix 1
Temporary Workaround	Block POST requests containing `Content-Encoding: deflate`

3. Source Review & Confidence

Source	Contribution	Confidence
SolarWinds CNA / CVE.org	Primary technical description, affected versions, mitigation, workaround	High
NVD	Independent normalization of CVSS, affected CPEs, KEV linkage	High
CISA KEV	Confirms active exploitation and remediation urgency	High

Assessment confidence is high because the core facts align across the CNA record, NVD, and CISA KEV enrichment. Detailed exploit tradecraft remains limited in the source set, so detection guidance is oriented toward exposure validation, HTTP anomaly detection, and service instability monitoring rather than exploit-signature certainty.

4. Vulnerability Details

The flaw allows unauthenticated remote attackers to crash SolarWinds Serv-U by sending specially crafted POST requests that include `Content-Encoding: deflate`. The published weakness classification is CWE-400, which is consistent with an attacker-driven resource consumption or parser-abuse condition that terminates or destabilizes the service.

The public record indicates affected versions include Serv-U 15.5.4 and earlier releases, with remediation delivered in 15.5.4 Hotfix 1. Because Serv-U is commonly exposed to the internet for managed file transfer workflows, the vulnerability can be reached pre-authentication and does not require user interaction.

5. Attack Scenarios

1. Internet-facing denial of service
 - An external adversary identifies exposed Serv-U instances and repeatedly sends crafted POST requests carrying `Content-Encoding: deflate`.
 - The Serv-U process crashes, interrupting file transfer availability for customers, partners, or internal workflows.
2. Opportunistic exploitation during scanning campaigns
 - Threat actors fold the bug into broad vulnerability-scanning infrastructure and target organizations with visible Serv-U panels or transfer endpoints.
 - Repeated probe-and-crash cycles create recurring outages and complicate root-cause triage.
3. Impact amplification against business-critical MFT infrastructure
 - Adversaries time requests during peak transfer windows, backups, or reporting deadlines to maximize operational disruption.
 - Even without data theft or code execution, the outage can materially affect revenue, contractual SLAs, and incident response workload.

6. Threat Landscape & Exploitation Status

CISA added CVE-2026-28318 to KEV on 2026-06-05, indicating evidence of active exploitation. That elevates the issue beyond a theoretical denial-of-service condition and supports emergency change handling for any organization running exposed Serv-U instances.

At present, the public record does not provide extensive exploit details, malware associations, or actor attribution. However, active exploitation plus the internet-facing nature of managed file transfer software makes this a practical target for both targeted disruption and automated mass scanning.

7. Affected Products and Exposure

Product / Surface	Exposure Consideration	Priority
SolarWinds Serv-U 15.5.4 and earlier	Directly affected per CNA/NVD	Immediate
Internet-facing Serv-U web / transfer endpoints	Highest likelihood of external reachability and opportunistic scanning	Immediate
Reverse-proxied or WAF-protected Serv-U instances	Risk may be reduced if malformed requests are blocked before origin	High
Internal-only Serv-U deployments	Lower exposure but still patch due lateral or insider abuse potential	High

Defenders should inventory public DNS, external load balancers, firewall NAT rules, and application owners for any Serv-U deployment. Validate whether HTTP request handling allows `Content-Encoding: deflate` requests to reach the origin service.

8. Mitigation and Workarounds

4. Upgrade all affected Serv-U deployments to 15.5.4 Hotfix 1.
5. If emergency patching is delayed, block POST requests containing `Content-Encoding: deflate` at WAF, reverse proxy, or upstream HTTP inspection points as recommended by SolarWinds.
6. Restrict internet exposure where feasible by IP allowlisting partner ranges or forcing access through VPN / private application access.
7. Monitor service restarts, crash loops, and repeated failed POST requests against Serv-U paths.
8. Review business continuity plans for managed file transfer dependencies in case of repeated service interruption.

9.1 Detection Opportunities

Signal	Rationale	Data Source
POST requests containing `Content-Encoding: deflate` to Serv-U	Closest published indicator aligned to vendor workaround	Reverse proxy, WAF, web logs
Repeated HTTP 5xx or abrupt connection resets on Serv-U endpoints	May indicate crash attempts or unstable service	Load balancer, web server, APM
Service crash / restart events for Serv-U processes	Direct evidence of successful denial-of-service	Windows Event Logs, service monitoring, EDR
Spikes in inbound requests from low-reputation or scanning IPs	Helps surface mass exploitation or probing	Firewall, IDS, network telemetry

9.2 Detection Query

```
// Hunt for suspicious requests and subsequent instability around SolarWinds Serv-U
let lookback = 14d;
let suspicious_clients = DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where RemotePort in (80, 443, 8080, 8443)
| where RemoteUrl has_any ("serv-u", "servu") or InitiatingProcessFileName has_any ("Serv-U", "ServU")
| summarize ConnectionCount=count(), DistinctIPs=dcount(RemoteIP) by DeviceName,
InitiatingProcessFileName, bin(Timestamp, 1h)
| where ConnectionCount > 20;
DeviceEvents
| where Timestamp > ago(lookback)
| where ActionType has_any ("ServiceStopped", "ServiceCrash", "ApplicationCrash")
| where FileName has_any ("Serv-U", "ServUDAemon") or InitiatingProcessFileName has_any ("Serv-U",
"ServUDAemon")
| project Timestamp, DeviceName, ActionType, FileName, InitiatingProcessFileName, ReportId
| join kind=leftouter suspicious_clients on DeviceName
| order by Timestamp desc
```

9.3 Exposure / Triage Query

```
// Identify likely Serv-U hosts and supporting owner context
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName has_any ("ServUDAemon.exe", "Serv-U.exe", "ServUAdmin.exe")
or ProcessCommandLine has_any ("Serv-U", "ServUDAemon")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), SampleCmd=any(ProcessCommandLine)
by DeviceName, FileName, FolderPath, InitiatingProcessAccountName
| order by LastSeen desc
```

10.1 Hunt Leads

- Correlate inbound web or reverse-proxy telemetry for Serv-U with downstream service restart or crash events.
- Review the hours before any outage for scanning from new ASN ranges, unusual geographies, or repeated POST sequences.
- Validate whether WAF or upstream controls already blocked `Content-Encoding: deflate` requests and whether bypass paths exist.

10.2 Hunt Query

```
// Pivot from service instability into surrounding network activity
let crash_window = DeviceEvents
| where Timestamp > ago(14d)
| where ActionType has_any ("ServiceStopped", "ServiceCrash", "ApplicationCrash")
| where FileName has_any ("Serv-U", "ServUDaemon")
| project DeviceName, CrashTime=Timestamp;
DeviceNetworkEvents
| where Timestamp > ago(14d)
| join kind=inner crash_window on DeviceName
| where Timestamp between (CrashTime - 30m .. CrashTime + 15m)
| where RemotePort in (80, 443, 8080, 8443)
| summarize Requests=count(), DistinctIPs=dcount(RemoteIP), SampleUrls=make_set(RemoteUrl, 10)
  by DeviceName, CrashTime, InitiatingProcessFileName
| order by CrashTime desc
```

11. MITRE ATT&CK Mapping

Tactic	Technique	Relevance
Impact	T1499 Endpoint Denial of Service	Publicly described outcome is service crash / availability loss
Reconnaissance / Resource Development	T1595 Active Scanning	Likely precursor activity for locating exposed Serv-U instances

12. Validation / Lab Testing

Validation should focus on defensive controls rather than exploit reproduction in production. Recommended checks:

9. Confirm all Serv-U instances are upgraded to 15.5.4 Hotfix 1.
10. Generate benign test requests through the reverse proxy path to verify rules blocking `Content-Encoding: deflate` POST traffic.
11. Confirm service monitoring and alerting trigger on Serv-U restarts, crashes, and sustained 5xx spikes.
12. Verify business owners for MFT systems can rapidly confirm whether outage symptoms map to this vulnerability.

13. Recommended Actions Summary

Priority	Action
Immediate	Upgrade to Serv-U 15.5.4 Hotfix 1
Immediate	Block POST requests containing `Content-Encoding: deflate` until all systems are patched
High	Identify every internet-facing Serv-U instance and confirm ownership
High	Alert on Serv-U crash / restart events and anomalous inbound

	request spikes
Medium	Reduce exposure with IP restrictions, VPN, or private access patterns where possible

14. References

13. CVE.org CNA record for CVE-2026-28318
14. NVD entry for CVE-2026-28318
15. SolarWinds advisory and 15.5.4 Hotfix 1 release notes
16. CISA Known Exploited Vulnerabilities catalog entry for CVE-2026-28318